

Livrables de l'équipe — entrées pour l'ERP

Atelier ISO 22361 — Malak · Hiba · Yao Landry

Projet n°3 · échéance 02/10/2026

Objet. Les trois livrables amont réalisés et remplis (Malak, Hiba, Yao Landry). Ils constituent les entrées concrètes pour développer le petit ERP hospitalier de l'atelier. La dernière section en tire la spécification de l'ERP.

Malak

Livrable 1 — Besoins de crise

1.1 Cartographie des actifs critiques

Actif / module	Criticité	Impact si indisponible
Dossiers patients (DPI)	Vitale	Soins interrompus, risque patient direct
Admissions / urgences	Vitale	Blocage de l'accueil des patients
Pharmacie / prescriptions	Vitale	Erreurs de médication possibles
Planning du bloc opératoire	Élevée	Déprogrammation d'interventions
Facturation / administratif	Moyenne	Retard de gestion, pas de risque vital

1.2 Analyse de risques et scénario retenu

Menace	Prob.	Impact	Niveau
Rançongiciel (chiffrement du SI)	Moyenne	Critique	MAJEUR — retenu
Fuite de données patients	Moyenne	Critique	Majeur
Panne matérielle serveur	Faible	Élevé	Modéré
Erreur humaine / suppression	Élevée	Moyen	Modéré

Scénario retenu : rançongiciel paralysant l'ERP, dossiers patients inaccessibles, menace de divulgation.

1.3 Seuils de déclenchement (incident → crise)

Signal détecté	Niveau	Conséquence
> 20 échecs d'authentification / min	Alerte	Notification équipe technique
Service ERP indisponible > 2 min	Incident	Ouverture d'incident
Altération / chiffrement de fichiers détecté	CRISE	Activation de la cellule de crise
Accès anormal en masse aux dossiers	CRISE	Activation + investigation

1.4 Rôles de la cellule de crise (CDC)

- **Pilote de crise** : décide, arbitre, déclenche/clôture la crise ;
- **Responsable technique** : évalue l'impact SI, exécute confinement et restauration ;
- **Responsable communication** : porte-parole, messages internes/externes ;
- **Secrétaire de crise** : journalise décisions et chronologie.

1.5 Exigences de continuité (mode dégradé)

- Consultation **en lecture seule** des dossiers des patients hospitalisés, même ERP principal indisponible ;
- Objectif de reprise (RTO) : service rétabli en < 4 h ; perte de données max (RPO) : < 24 h (dernière sauvegarde).

2.1 Format des événements émis par l'ERP

Chaque action sensible ou événement de sécurité produit une ligne de log au format JSON :

```
{
  "timestamp": "2026-10-01T14:32:10Z", // horodatage ISO 8601
  "level": "CRITICAL", // INFO | WARNING | CRITICAL
  "event_type": "file_integrity", // type evenement
  "source": "erp-core", // module émetteur
  "user": "svc_account", // acteur (ou null)
  "message": "Altération de fichiers détectée",
  "details": { "count": 128 } // contexte libre
}
```

2.2 Niveaux de gravité

Niveau	Signification	Action dashboard
INFO	Opération normale tracée	Ligne dans la timeline
WARNING	Signal suspect (seuil d'alerte)	Indicateur orange
CRITICAL	Seuil de crise franchi	Bascule en mode crise + alerte CDC

2.3 Points d'accès (API) exposés par l'ERP

Endpoint	Méthode	Rôle
/health	GET	État de santé de l'ERP (up/down, base, latence)
/events	GET	Flux des événements récents (JSON) pour le dashboard
/status/degraded	GET/POST	Lire ou activer le mode dégradé lecture seule

2.4 Mode d'échange et fréquence

- Le dashboard interroge **/health** toutes les 5 s et **/events** toutes les 2 s (polling) ;
- Alternative : l'ERP écrit les logs dans un fichier partagé **events.log** lu par le dashboard ;
- Tous les horodatages en UTC, format ISO 8601.

3.1 Environnement de déploiement

- **Conteneurs Docker** sur un réseau privé isolé (172.16.10.0/24), sans accès Internet ;
- Services : **erp-core** (application), **erp-db** (base de données), **dashboard** (supervision) ;
- Ports internes : ERP 8000, base 5432, dashboard 8501 ; aucun port exposé hors du lab.

```
# Réseau isolé 172.16.10.0/24
erp-core 172.16.10.10 : 8000 (application + API /health,/events)
erp-db 172.16.10.11 : 5432 (données FICTIVES uniquement)
dashboard 172.16.10.20 : 8501 (conscience partagée de crise)
poste-test 172.16.10.30 (déroulement de l'exercice)
```

3.2 Politique de sauvegarde

Paramètre	Valeur
Fréquence	Sauvegarde complète de la base toutes les 24 h + avant l'exercice
Emplacement	Volume séparé, hors de portée du conteneur ERP
Restauration	Script de restauration testé ; objectif < 30 min
Rôle	Base du rétablissement (5.3.6) après la crise

3.3 Collecte des logs

- Les logs de l'ERP sont centralisés dans un volume partagé lisible par le dashboard ;
- Conservation horodatée pour permettre la génération du REX en fin d'exercice ;
- Aucune donnée réelle : jeu de données patients entièrement fictif.

Synthèse — spécification du petit ERP à développer

En combinant les trois livrables, l'ERP de l'atelier doit réunir :

Composant	Contenu	Issu de
Modules métier	Patients, admissions, pharmacie (données fictives)	Malak 1.1
Rôles & droits	Rôles normaux + rôles de crise (pilote, technique...)	Malak 1.4
Journal d'audit	Log horodaté JSON de toute action sensible	Hiba 2.1
Détection de seuils	Compteurs (échecs auth, intégrité fichiers)	Malak 1.3
API supervision	/health, /events, /status/degraded	Hiba 2.3
Mode dégradé	Lecture seule des dossiers hospitalisés	Malak 1.5
Sauvegarde/restauration	Dump base + script de restore	Yao Landry 3.2
Déploiement	Docker, réseau isolé, données fictives	Yao Landry 3.1

Cadre de sécurité de l'atelier. L'ERP tourne uniquement dans le réseau isolé du lab, avec des données patients entièrement fictives. Le point faible servant à déclencher l'exercice est **documenté, convenu par l'équipe et confiné au lab** ; il ne vise aucun système réel. L'objet évalué reste la **réponse de crise** selon ISO 22361, pas l'attaque.